

中机创新科技发展（重庆）有限公司

信息安全管理制

文件编号：ZJCK-06-11

编制部门：经营拓展部 编制时间：2026.01.10

版 本：V 1 . 0 审核时间：2026.01.10

批 准 人：李凯 审批时间：2026.01.10

修订记录

修订日期	版本	变更说明	修订人	审批人	批准人
2026.1.10	V1.0	新建	陶海波	邹雪	李凯

目录

中机创新科技发展（重庆）有限公司..... 1

信息安全管理制度 1

1. 总则 4

 1.1. 目的 4

 1.2. 适用范围 4

 1.3. 原则与策略框架 4

2. 定义与术语 5

3. 角色与职责 5

4. 信息安全管理活动 6

 4.1. 管理流程概述 6

 4.2. 资产识别与分类 6

 4.3. 风险评估与处置 6

 4.4. 信息安全事件管理 7

 4.5. 定期评审与改进 7

5. 信息安全策略体系 7

 5.1. 总方针与核心要求 7

 5.2. 人员安全管理 7

 5.3. 第三方安全管理 8

6. 信息安全培训管理 8

 6.1. 培训目标与责任 8

 6.2. 培训内容与对象 8

 6.3. 培训实施与记录 9

 6.4. 培训效果评估与更新 9

7. 与其他流程的接口 9

8. 考核指标 9

9. 附则 10

1. 总则

1.1. 目的

为系统化构建、实施、运行、监控、评审、维护和改进公司信息安全治理体系，规范运维服务全过程中的信息安全管理，确保客户与公司信息的保密性、完整性、可用性及合规性，有效管理风险并应对安全事件，保障业务持续稳定，特制定本制度。

1.2. 适用范围

本制度适用于公司所有部门及员工，覆盖所有运维服务项目及支撑活动中所涉及的信息资产（包括但不限于客户数据、应用系统、源代码、配置信息、服务知识、管理文档等）的全生命周期安全管理。

1.3. 原则与策略框架

公司信息安全遵循“三分技术，七分管理”的核心思想，建立以下原则与分层策略框架：

战略一致原则：信息安全目标与公司业务战略及客户服务承诺保持一致。

预防为主原则：将安全要求融入运维服务各环节，主动识别并控制风险。

责任明确原则：实行“谁主管谁负责，谁运营谁负责，谁使用谁负责”的安全责任制。

持续改进原则：基于PDCA（计划-执行-检查-处理）循环，实现安全能力的持续提升。

合规合法原则：严格遵守国家法律法规、行业监管要求及合同中的安全承诺。

本制度是公司信息安全的纲领性文件，其下设的各类具体安全规范、操作指南及技术标准共同构成完整的信息安全策略体系。

2. 定义与术语

信息资产：任何对公司或客户具有价值，需要加以保护的硬件、软件、数据、服务或人员能力。

信息安全风险：人为或自然的威胁利用信息资产及其管理过程中的脆弱性，导致安全事件发生，并对资产造成损害的可能性及影响。

信息安全事件：系统、服务或网络状态的一种可识别的、违反信息安全策略或降低服务安全等级的occurrence。

脆弱性：可能被威胁利用的资产或控制措施的弱点。

3. 角色与职责

角色	主要职责	对应岗位
信息安全负责人	1. 制定并维护公司信息安全方针、策略和制度体系。 2. 领导公司级信息安全风险评估与管理决策。 3. 审批重大安全改进计划与资源投入。 4. 主持管理评审，向公司管理层报告安全状况。	总经理或指定副总经理
信息安全管理团队	1. 负责本制度的日常推行、解释与修订。 2. 组织协调跨部门的安全风险评估、应急演练与审计活动。 3. 监督各项安全控制措施的执行情况。 4. 统筹信息安全事件的调查、分析与报告。	经营拓展部经理（牵头） 质量部经理 技术研发中心经理
运维项目经理	1. 是所负责项目的安全直接责任人。 2. 组织实施项目内信息资产识别、风险评估与控制。 3. 确保项目团队遵守安全规定，落实安全操作。 4. 负责项目内安全事件的初步处置与报告。	经营拓展部-运维项目经理
技术执行人员	1. 负责所辖技术资产的具体安全配置、防护与监控。 2. 执行漏洞修复、安全加固等风险处置措施。 3. 及时报告发现的安全漏洞或异常行为。	经营拓展部-运维工程师 技术研发中心-开发/测试工程师
综合管理部	1. 组织落实全员信息安全意识教育与基础培训。 2. 管理员工背景审查、保密协议签订及离职安全审核。 3. 将安全表现纳入绩效考核参考。	综合管理部经理/专员
质量部	1. 独立监督本制度及所有安全流程的执行合规性。 2. 组织或参与信息安全内部审计。 3. 将安全指标纳入公司质量目标与监控体系。	质量部经理/专员

角色	主要职责	对应岗位
全体员工	1. 了解并遵守公司信息安全相关规定。 2. 保护自身掌握的账户、密码及信息资产。 3. 有责任报告发现的安全隐患或事件。	公司全体员工

4. 信息安全管理活动

4.1. 管理流程概述

信息安全管理核心是建立一个动态、闭环的管理模型，持续循环以下四个关键活动：资产识别与评估→风险识别与分析→ 风险处置与控制→监控评审与改进。

4.2. 资产识别与分类

识别：在新项目启动、新系统上线或服务范围重大变更时，由运维项目经理主导，识别服务范围内的所有关键信息资产，形成并维护《信息资产清单》。

分类与分级：依据资产对业务的重要性及安全属性（保密性、完整性、可用性）的影响程度，对资产进行分类和分级（如：核心、重要、一般），并据此确定相应的保护级别。

4.3. 风险评估与处置

风险评估周期：至少每年进行一次全面的信息安全风险评估。在发生重大变更、安全事件或法律法规更新时，应启动专项评估。

评估方法：采用定性与定量相结合的方法，评估威胁利用脆弱性对资产造成损害的可能性及影响，计算风险值并确定风险等级（高、中、低）。

风险处置：

降低风险：对于不可接受的风险，制定并实施技术或管理控制措施（如部署防护设备、修改流程）。

规避风险：通过取消可能导致风险的活动来避免风险。

转移风险：通过购买保险、签署服务协议等方式将风险转移给第三方。

接受风险：经信息安全负责人批准，对在成本效益分析后决定接受的风险，需明确接受条件并持续监控。

变更中的风险管理：所有变更请求（RFC）必须包含信息安全影响评估。变更顾问委员会（CAB）应将安全风险评估作为审批的必要依据。

4.4. 信息安全事件管理

事件受理与响应：所有信息安全事件必须通过服务台统一受理，并严格遵循《事件管理制度》进行分级（通常定义为高级别事件）、响应、升级和处置。

调查与分析：重大信息安全事件在应急处置后，必须依据《问题管理制度》启动根本原因分析（RCA），防止再发生。

报告与改进：经营拓展部应定期（每季度）分析信息安全事件，形成报告，并驱动安全控制措施和流程的改进。

4.5. 定期评审与改进

信息安全管理团队应至少每年组织一次管理评审，结合风险评估结果、安全事件分析、审计发现、相关方反馈及内外部环境变化，全面评审信息安全管理体系的持续适宜性、充分性和有效性，并输出明确的改进决策。

5. 信息安全策略体系

5.1. 总方针与核心要求

公司承诺保护所有信息资产免受内外部威胁，确保业务连续性。所有员工及第三方在访问公司或客户信息资产时，必须遵守“业务需要才知密，最小权限可访问，所有操作留痕迹”的基本原则。

5.2. 人员安全管理

聘用：关键岗位人员聘用前需进行必要的背景审查。

协议：所有员工入职时必须签署《保密协议》及《信息安全责任书》。

离职：员工离职时，必须立即回收所有权限，并完成信息资产交接。

5.3. 第三方安全管理

协议约束：与供应商、合作伙伴等第三方签署的合同或协议中，必须包含明确的信息安全责任条款。

风险评估：对能够访问或处理公司/客户敏感信息的第三方，应在合作前进行安全能力评估，并在合作期间定期审计。

持续监控：经营拓展部与采购部共同负责对关键第三方的安全表现进行监控。

6. 信息安全培训管理

6.1. 培训目标与责任

为确保不同层级员工具备相适应的安全意识和能力，建立分层培训体系。

综合管理部：作为培训归口管理部门，负责制定年度全员安全培训计划、组织通用安全意识培训、维护培训记录。

经营拓展部/技术研发中心：负责制定并提供专业技术安全培训内容与讲师。

各部门负责人：负责督促本部门员工完成培训要求。

6.2. 培训内容与对象

培训类别	主要对象	核心内容	最低频率
全员意识培训	全体员工	信息安全方针、基本概念、法律法规、社交工程防范、日常安全守则、事件报告流程。	入职后1个月内完成，之后每年1次
岗位技能培训	运维工程师、开发工程师、测试工程师等	安全开发规范、系统安全加固、漏洞扫描与修复、日志安全分析、应急响应操作等。	每年至少1次

培训类别	主要对象	核心内容	最低频率
管理层培训	各级管理人员	信息安全战略、风险管理、法律法规责任、业务连续性管理。	每年至少1次

6.3. 培训实施与记录

培训可采用线上课程、线下讲座、演练等多种形式。

所有培训需保留完整的记录，包括：培训通知、签到表、课件、考核成绩（如有）。

员工培训档案由综合管理部统一管理，培训完成情况作为岗位授权和晋升的参考依据。

6.4. 培训效果评估与更新

通过问卷、考试、模拟演练等方式评估培训效果。

质量部应定期对培训计划的落实情况和效果进行抽查。

培训内容应根据安全威胁形势、技术发展、制度更新和评估反馈进行动态调整和优化。

7. 与其他流程的接口

服务级别管理：SLA中应明确安全服务目标（如安全事件响应时间、漏洞修复SLA）。

事件管理：是信息安全事件处置的主流程。

问题管理：用于分析信息安全事件的根因并实施长效改进。

变更管理：是实施安全加固、漏洞修复等风险控制措施的核心路径。

配置管理：CMDB是信息资产清单的技术基础，确保安全控制对象准确无误。

发布管理：确保只有经过安全测试和授权的版本才能上线。

8. 考核指标

KPI	目标值	计算公式/方法	频度
信息安全事件数量	≤1次	我方人员造成信息安全事件的次数	年度

9. 附则

本制度由经营拓展部负责解释与修订。

本制度自发布之日起生效，原相关规定同时废止。

本制度涉及的相关模板（《信息资产清单》、《信息安全风险评估表》等）由信息安全管理团队负责制定与维护。

公司将依据本制度，陆续制定并发布具体的分项安全管理方法与操作指南

。